JustCmul8

EDITION 2

TECHNICAL ASSESSMENT · OCTOBER 2026

Production Readiness & Scale Report

Where JustCmul8 stands today: what has already been hardened, how it measures against DPDP and OWASP, what is still missing, and the full checklist a real-world software product needs, from security and scale to licences and paperwork.

Verdict: beta-ready, not yet launch-ready

Prepared for	Date	Scope
JustCmul8 team	26 October 2026	justcmul8-rebuild @ e02477d

00 EXECUTIVE SUMMARY

Hardened today, nine steps from a paid launch

Edition 2 adds the security sprint completed on 26 October 2026, a full DPDP and OWASP assessment, AI-security mapping, engine-accuracy findings and a real-world launch checklist.

JustCmul8's core design is strong: **simulations run in each user's browser**, so server cost grows with saves, AI requests and collaboration, not with simulation volume. Today's sprint closed every known vulnerability in production code (a Next.js proxy bypass and a DOMPurify XSS, both critical), added DPDP-style sign-up consent with an auditable record, and fixed two user-facing UI issues.

What stands between beta and a paid launch is mostly operational: commercial hosting plans, a real email sender, Razorpay live mode, monitoring, and two marketing claims that are not true. DPDP and OWASP are each **partly met**; neither is a certificate, and the gaps are listed item by item in sections 04 and 05.

0
known vulnerabilities in production dependencies (was 9, incl. 2 critical)

9
launch blockers still open before charging money

5 / 13
DPDP requirements fully met; 6 more partly met

3 / 10
OWASP Top 10 (2025) categories strong; 6 partly covered

Contents

01 Implemented so far
02 Why JustCmul8 is strong
03 Launch blockers
04 DPDP Act compliance
05 OWASP Top 10 (2025)
06 AI & agentic security
07 Scaling to many users
08 Simulation engine accuracy
09 Real-world software checklist
10 Licences, legal & registrations
11 Next steps & roadmap
12 Sources, method & limits

00 EXECUTIVE SUMMARY · SCORECARD

Readiness at a glance

One line per area. Details and evidence follow in the numbered sections.

AREA	STATUS	FINDING
Simulation architecture	STRONG	Client-side engine; scales with users at near-zero server cost.
Security baseline	STRONG	RLS on every table, CSP + HSTS, rate limits, signed webhooks, re-auth for deletion; dependencies patched today.
AI safety	GOOD	Bounded, validated AI edits; untrusted-data fencing; output-token caps; credits.
Privacy (DPDP)	PARTIAL	Consent, age gate, erasure and correction done; logs, breach process, grievance contact missing.
Hosting & email	BLOCKER	Commercial plans and a production email sender needed (if still on defaults).
Payments	PARTIAL	Integration complete in test mode; KYC and live keys pending.
Observability	MISSING	No error tracking, alerting, audit log or error pages.
Engine accuracy	FIXED	Breakdowns, priority, decision paths, line rules, bursts and tank drain now applied (commit `ff86017`, pending deploy).
Truth in marketing	BLOCKER	"Trusted by" brand logos and two Enterprise features are not real.

Bottom line

The engineering foundation is production-grade; the remaining work is mostly accounts, policies and observability. With Phase 0 of the roadmap closed (about one to two weeks), JustCmul8 can take real payments with confidence.

01 IMPLEMENTED SO FAR

What is already done

Two lists: the changes shipped to production on 26 October 2026, and the controls that were already in the product before this review.

Shipped on 26 October 2026 (live at justcmul8.vercel.app)

CHANGE	WHAT IT DOES	COMMIT
Next.js 16.2.10 → 16.4.3	Closes a critical middleware/proxy bypass advisory (GHSA-6gpp-xcg3-4w24). Our proxy enforces login redirects and the API CSRF gate.	`e02477d`
DOMPurify 3.4.17	Closes a critical DOM-XSS advisory in the PDF-export dependency (jsPDF). Production dependencies now report 0 vulnerabilities.	`e02477d`
Sign-up consent (DPDP)	Two unticked boxes, "I am 18 or older" and "I agree to the Terms and consent to processing per the Privacy Policy", required for email, Google and GitHub sign-up.	`e02477d`
Consent record	Policy version and acceptance time stored with the account. OAuth sign-ups are recorded server-side at the callback; onboarding asks anyone who skipped the sign-up page. Existing users are unaffected.	`e02477d`
Privacy & Terms	18+ only; Gmail listed as a processor for invitation emails; consent recording disclosed.	`e02477d`
Account-deletion confirmation	A dedicated popup lists what will be deleted and requires typing DELETE.	`14bfc07`
Older-browser rendering	Gradients emit a plain fallback before the oklab version, so buttons and headings stay visible on older browsers.	`b1dfd7d`

Each change was verified with a typecheck, 212/212 unit tests, a production build and the relevant end-to-end suites (23 tests, including a new consent test that never creates an account).

Controls already in place before this review

- Row-level security on every table
- CSP, HSTS, frame, referrer and permissions headers
- Postgres-backed rate limiting on sensitive routes
- Same-origin CSRF gate on API routes
- Razorpay webhook HMAC (timing-safe) and replay protection
- Re-authentication within 10 minutes before account deletion
- Size caps on collaborator-writable project data
- Only editors may broadcast graph changes in realtime
- Share links are 128-bit tokens, excluded from search engines
- AI edits validated: max 60 ops, confirmation for more than 5 deletes
- Collaborator labels escaped before entering generated Python
- No ad trackers, analytics trackers or third-party cookies
- One-click account and data deletion
- Automated accessibility checks (axe) on public pages

02 WHY JUSTCMUL8 IS STRONG

Strengths a buyer can check

Each point is backed by the code, not by intent. These are the arguments to use with customers and reviewers.

Compute runs on the user's device

SCALE

The SimPy engine runs in a Web Worker via Pyodide. A thousand people running models at once adds almost no server load, and model data never leaves the browser to be simulated.

Defence in depth

SECURITY

Database rules (RLS), server checks, a CSRF gate, strict headers and rate limits each stop attacks on their own, so one mistake does not expose user data.

Privacy by design

PRIVACY

No ad or analytics trackers, minimal data collected, one-click deletion, and consent recorded with the policy version.

The AI proposes, code decides

AI SAFETY

Every AI change is validated and bounded; destructive changes need the user's confirmation; project text is treated as untrusted.

Tamper-proof billing

PAYMENTS

Credits change only through server functions; payment webhooks are signature-checked and cannot be replayed.

Tested and patched

QUALITY

212 unit tests plus end-to-end and accessibility suites; production dependencies at zero known vulnerabilities.

Permission-aware realtime

COLLABORATION

Viewers can watch but cannot push edits; the database, not the browser, decides who may broadcast.

Current, supported platform

MODERN STACK

Next.js 16, React 19, Supabase and Tailwind v4 on managed infrastructure, HTTPS everywhere.

Say it honestly

"Production-ready" should not be claimed until section 03 is closed. Until then, "in beta" is accurate and still persuasive given the strengths above.

03 LAUNCH BLOCKERS

Close these before taking payments

Status as of 26 October 2026. "Team" items need an account owner, a payment method or legal authority; "Code" items can be done in the repository.

#	ITEM	WHY IT BLOCKS LAUNCH	OWNER	STATUS
1	**Vercel Hobby → Pro** ~$20 per member / month	Hobby is limited to non-commercial use; taking payments is commercial.	TEAM	UNVERIFIED
2	**Supabase Free → Pro** $25 / month base	Free projects pause after a week idle and have no automatic backups. Pro adds daily backups and 500 realtime connections.	TEAM	UNVERIFIED
3	**Production email sender** Resend, Amazon SES or Postmark	Supabase's default mailer reaches only team addresses, 2/hour. Invites use a personal Gmail account.	TEAM	UNVERIFIED
4	**Razorpay live mode**	KYC, live keys, live plans and a live webhook. Needs a refund/cancellation policy page.	TEAM	OPEN
5	**Remove "Trusted by" logos**	Amazon, Google, Tesla, Uber and others appear under "Trusted by teams at world-class companies". None is a customer: a misleading claim and a trademark risk.	CODE	OPEN
6	**Fix Enterprise claims**	Pricing lists "SSO integration" and "Dedicated compute"; neither exists.	CODE	OPEN
7	**Gemini on paid billing**	Free-tier prompts may be used to improve Google's products; limits are low. Add a budget alert.	TEAM	UNVERIFIED
8	**Monitoring & error pages**	No Sentry (or similar), no `error.tsx` / `global-error.tsx` : crashes show a blank page and nobody is alerted.	CODE	OPEN
9	**Domain, staging, private repo**	Own domain for `hello@justcmul8.com` ; separate staging database for tests; the GitHub repository is still public.	TEAM	OPEN

"Unverified": production plan tiers, SMTP settings and the Gemini billing tier could not be inspected during this review. Mark them done once confirmed in each dashboard.

Highest risk: item 5

Every other blocker affects how well the product works. This one can create legal liability on day one. Replace it with real pilot users or institutions that have given permission, or remove the row.

04 DPDP ACT 2023 & RULES 2025

Privacy law: half-way, with a clear path

India's Digital Personal Data Protection Act applies to JustCmul8 as a Data Fiduciary. The Rules were notified in November 2025; full compliance is due by 13 May 2027. Penalties reach ₹250 crore for failing to protect data.

MET PARTIAL MISSING

REQUIREMENT	STATUS	WHAT THE PRODUCT DOES TODAY	WHAT TO IMPLEMENT
Notice	PARTIAL	Privacy Policy lists data, purposes, processors, rights, transfers and children.	Itemised notice at sign-up; lawyer review; Hindi version.
Consent	MET	Unticked, separate boxes for age and consent, required for every sign-up method. NEW	Re-ask when the policy version changes.
Consent record	MET	Policy version and time stored with the account. NEW	Show it to the user in Settings.
Withdraw consent easily	PARTIAL	Account deletion only.	Settings switch to withdraw consent for AI processing.
Right to access	PARTIAL	Simulation results export (CSV, HTML, PDF).	"Download my data": profile, projects, consent record.
Right to correction	MET	Profile editable in Settings.	—
Right to erasure	MET	One-click deletion of profile, projects, history and chats.	Document billing-record retention.
Grievance redressal	PARTIAL	Email address; 30-day reply promise.	Named grievance contact and a ticket log (Rules allow up to 90 days).
Children	MET	18+ declaration required at sign-up; policy updated. NEW	—
Security safeguards	PARTIAL	Encryption in transit and at rest, RLS, access control.	Audit/processing logs kept ~1 year; backups; access reviews.
Breach notification	MISSING	No process.	Runbook: inform affected users and the Board without delay; detailed report within 72 hours.
Processors	PARTIAL	Supabase, Vercel, Razorpay, Google, GitHub listed.	Accept each provider's DPA; move Gemini to the paid tier.
Retention	MISSING	Kept while the account is open; "server logs for a short period".	Written retention schedule; erase inactive accounts after notice.

Of 13 rows: 5 met, 6 partial, 2 missing. Figures such as one-year log retention come from secondary summaries of the Rules; confirm with the notified text or counsel. Cross-border transfer is permitted except to countries the Government restricts; none of our processors is affected today.

05 OWASP TOP 10 · 2025

Web security, category by category

OWASP has no certificate; "OWASP-aligned" means each Top 10 risk is addressed. Evidence below is from the source code at `e02477d`.

CATEGORY	STATUS	EVIDENCE	NEXT ACTION
A01 Broken Access Control	STRONG	RLS on every table; server-side checks in every API route; only editors may broadcast edits.	Expiring, revocable share links.
A02 Security Misconfiguration	PARTIAL	CSP, HSTS, X-Frame-Options, nosniff, referrer and permissions policies.	Nonce-based CSP instead of `unsafe-inline`; private repo; WAF rules.
A03 Supply Chain Failures	PARTIAL	0 production vulnerabilities after today's upgrades; lockfile committed.	Pin SimPy and self-host Pyodide; Dependabot and `npm audit` in CI; 3 dev-only test-runner issues.
A04 Cryptographic Failures	STRONG	HTTPS + HSTS; passwords hashed by Supabase Auth; timing-safe HMAC comparison.	Rotate keys on a schedule.
A05 Injection	STRONG	Parameterised queries; React escaping; chat markdown with HTML skipped; labels JSON-escaped into Python.	Keep the generator's escaping rule in code review.
A06 Insecure Design	PARTIAL	Re-auth for deletion; credits and rate limits; server-only credit changes.	Bot protection (Turnstile) on sign-up and login.
A07 Authentication Failures	PARTIAL	Supabase Auth with OAuth; password strength meter; re-auth for sensitive actions.	MFA (TOTP); leaked-password protection; captcha.
A08 Software & Data Integrity	PARTIAL	Webhook signatures and replay protection.	Integrity (SRI) or self-hosting for the engine loaded from a CDN.
A09 Logging & Alerting	MISSING	Console logs only.	Audit log, Sentry, alerts on auth and billing anomalies.
A10 Exceptional Conditions	PARTIAL	Errors handled in API routes; rate limiter degrades deliberately to memory.	Error boundaries (`error.tsx` , `global-error.tsx`); alert when degraded.

To claim "OWASP-aligned"

Close A09, then A07 and A06 (MFA, captcha), then run an OWASP ZAP scan or a third-party pentest and keep the report. For larger customers, OWASP ASVS Level 1 is the next yardstick.

06 AI & AGENTIC SECURITY

The assistant against the OWASP LLM Top 10

The assistant reads user-controlled text and writes changes to the canvas, so it is assessed against the OWASP Top 10 for LLM Applications (2025).

RISK	STATUS	CONTROL TODAY	ADD
LLM01 Prompt Injection	GOOD	Project data fenced as untrusted; edits validated regardless of what the model was told.	Automated red-team test suite.
LLM02 Sensitive Info Disclosure	PARTIAL	Only the model sections the assistant needs are sent.	Gemini paid tier so prompts are not used for training.
LLM03 Supply Chain	GOOD	Model router with fallbacks; official SDK.	Pin the model list per release.
LLM04 Data & Model Poisoning	N/A	No fine-tuning or training on user data.	—
LLM05 Improper Output Handling	STRONG	Output parsed and bounded; markdown without raw HTML; CSP blocks exfiltration images.	—
LLM06 Excessive Agency	STRONG	Only graph edits; max 60 ops; deletes over 5 need confirmation.	One-click undo of the last AI change.
LLM07 System Prompt Leakage	GOOD	Prompts hold no secrets; keys stay in server environment variables.	—
LLM08 Vector & Embedding	N/A	No retrieval or embeddings.	Review if RAG is added.
LLM09 Misinformation	PARTIAL	Flow analysis computed in code and passed to the model.	Label AI insights as suggestions; link to the measured KPI.
LLM10 Unbounded Consumption	PARTIAL	Credits; 20/min per user and a global limit; output-token caps.	Daily token caps; Google Cloud budget alerts.

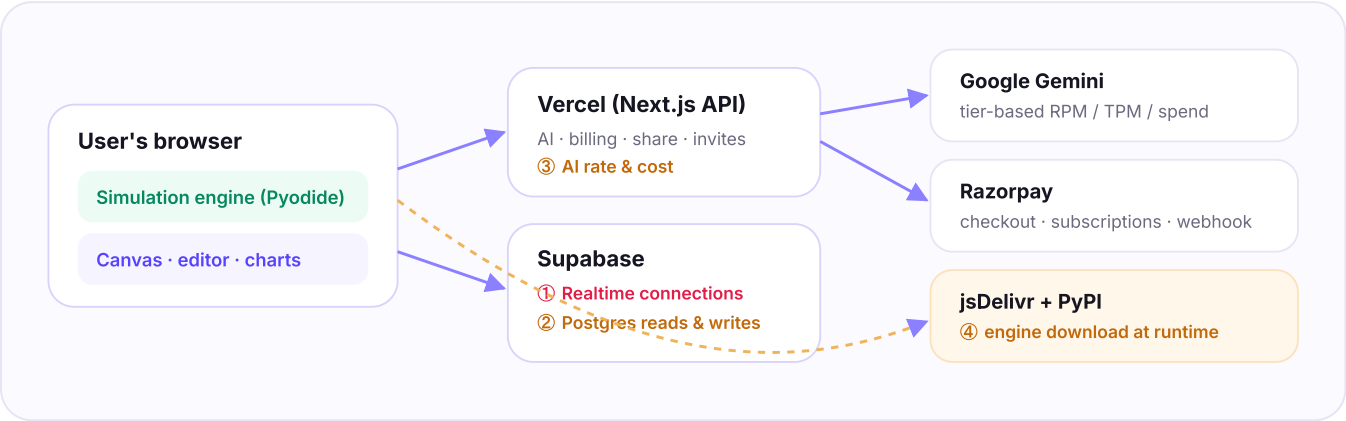
Rule for any future AI feature

The model may propose; code decides what is allowed; the user confirms anything destructive. New tools (web fetch, code execution, email) need a sandbox, an allowlist and no access to secrets or the service-role key.

07 SCALING

What breaks when many people arrive

Load lands on four places. Simulation itself is not one of them.



SUPABASE REALTIME LIMIT	FREE	PRO	PRO, NO SPEND CAP	TEAM
Concurrent connections	200	500	10,000	10,000
Messages per second	100	500	2,500	2,500
Presence messages per second	20	50	1,000	1,000
Max broadcast payload	256 KB	3,000 KB on paid plans		

① Realtime: cursor flood — BREAKS FIRST

Cursors are sent every animation frame (~60 msg/s per user). Ten people moving at once ≈ 600 msg/s, above Pro's 500, and Supabase disconnects clients.

Fix: throttle to 10–15/s and send only when others are present; later a CRDT (Yjs) for co-editing.

② Database — GROWS WITH USERS

The dashboard runs `select("*")`, loading every project's full graph. Two indexes are missing; run results never expire.

Fix: select needed columns and paginate; index `simulation_runs(project_id)` and `project_shares(project_id)`; `(select auth.uid())` in RLS; retention.

③ AI requests — COST

Gemini limits depend on the account tier; the global limiter updates one database row per call.

Fix: paid tier, daily token caps, retry with backoff, a queue for bursts.

④ Engine download — SINGLE POINT OF FAILURE

Pyodide 0.24.1 (2023) from jsDelivr and SimPy from PyPI on every session; if either is down, simulations stop.

Fix: self-host a current Pyodide and a pinned SimPy wheel; move 108 MB of video to a media CDN.

No load test has been run. Before launch, run k6 with ~500 concurrent editors plus API traffic against staging.

08 SIMULATION ENGINE ACCURACY

Results must be right, not just fast

While writing the Simulation Playbook, the generated SimPy code was checked against every setting in the block panels. Several settings were shown to users but not applied by the main engine, a credibility risk for a simulation product. Six of the seven are now fixed.

FINDING	EFFECT FOR THE USER	VERIFIED	STATUS
Breakdowns not simulated	MTBF and repair time exist only in the old fallback engine; machines never fail in the main engine.	IN CODE	FIXED
Priority ignored	Resources are requested without priority, so VIP queues, Fast-Track and priority tiers have no effect.	IN CODE	FIXED
Decision paths not created from arrows	Routing uses only paths added with "Add Path"; drawing arrows alone leaves items stuck, with no warning.	IN CODE	FIXED
Waiting Line capacity and order	Capacity and LIFO/priority order reported as not enforced.	CONFIRMED	FIXED
Tanks never drain	Arriving batches add level; tanks reported as never emptying.	CONFIRMED	FIXED
"Rush Hour / Burst Spikes"	Reported to behave like plain random arrivals.	CONFIRMED	FIXED
KPI unit labels	Some cards say "min" or "ms" while the engine works in seconds.	REPORTED	OPEN

Fixed in commit `ff86017` with 12 new engine tests (229 unit tests pass). Results are byte-identical for graphs that don't use these settings; templates with a finite line capacity now drop arrivals when the line is full. New options: "Rush Hour" bursts with a group size, and a tank Drain Rate. Not yet deployed at the time of writing.

Keep results trustworthy

Deploy the fixes, then refresh the Simulation Playbook guides that worked around them. Add an automated "golden results" suite (fixed seed, every template) so future engine changes can never silently shift results.

09 REAL-WORLD SOFTWARE CHECKLIST

Everything a real product needs

Beyond code: the operations, process and support that customers, auditors and payment providers expect. Ticked items exist today; boxes are to do.

OPERATIONS

- [ ] **Error tracking** (Sentry) with release tags
- [ ] **Uptime monitor** and a public status page
- [ ] **Audit log**, kept ~1 year (DPDP)
- [ ] **Backups** + point-in-time recovery; quarterly restore drill
- [ ] **Disaster-recovery targets**, e.g. RPO 24 h, RTO 4 h
- [ ] **Incident runbook** including the 72-hour breach report
- [ ] **Support inbox** and a response-time promise

ENGINEERING PROCESS

- [x] Unit, end-to-end and accessibility test suites
- [ ] **CI**: typecheck, tests, lint, `npm audit` on every push
- [ ] **Staging** environment with its own database
- [ ] **Preview deploys** per pull request (connect Vercel to GitHub)
- [ ] **Branch protection** and code review on `main`
- [ ] **Dependabot** and secret scanning
- [ ] **Key rotation** schedule; secrets only in the platform vault
- [ ] **Load test** before launch and before big campaigns

SECURITY PROGRAMME

- [x] RLS, headers, rate limits, signed webhooks
- [x] Dependencies at 0 known production vulnerabilities
- [ ] **MFA** for users; mandatory for admins
- [ ] **Captcha** (Turnstile) on sign-up, login and reset
- [ ] **WAF** rules and bot protection on Vercel
- [ ] **Pentest** or OWASP ZAP scan, report kept
- [ ] **security.txt** and a vulnerability-disclosure contact
- [ ] **Access review** of who holds production keys

PRODUCT & CUSTOMER

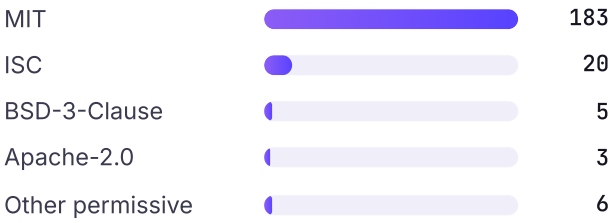
- [x] Accessibility checks (axe) on public pages
- [x] Dark mode and responsive layouts
- [x] Simulation Playbook as a first help guide
- [ ] **Help centre** and in-app docs
- [ ] **Privacy-friendly analytics** (aggregate only), disclosed
- [ ] **Transactional emails**: welcome, receipt, trial ending
- [ ] **GST-compliant invoices** for subscriptions
- [ ] **Changelog** and release notes

10 LICENCES, LEGAL & REGISTRATIONS

Open source is clean; paperwork is next

Licences of all 217 packages in the production dependency tree, runtime components loaded from CDNs, legal documents and business registrations.

Production dependencies by licence



Other: 0BSD, MIT-0, CC0-1.0, MIT AND Zlib, MIT AND ISC, CC-BY-4.0 (`caniuse-lite`). No copyleft in the npm tree. Counted before today's upgrade, which changed versions, not licences.

Runtime, assets & own code

- ✓ **Pyodide**: MPL-2.0, fine used unmodified
- ✓ **SimPy**: MIT
- ✓ **Inter, Space Grotesk, Great Vibes**: SIL Open Font Licence
- ☐ **Brand logos**: icon files are CC0, but trademarks stay with each company; remove "Trusted by"
- ☐ **Third-party notices** page (Apache-2.0 and CC-BY attribution)
- ☐ **Own code**: no LICENSE file and a public repo; make it private

Legal documents

DOCUMENT	STATUS	NOTE
Terms of Service	DRAFT	Live; governing law India; updated today for 18+; needs a lawyer's review.
Privacy Policy	DRAFT	Live and updated today; review against section 04.
Refund & cancellation policy	MISSING	Required by Razorpay for live mode.
Acceptable use policy	MISSING	Abuse of AI credits, scraping, illegal content.
Data Processing Agreement	MISSING	Template for business customers who upload their own data.
SLA	LATER	Only once an Enterprise plan is real.

Business registrations (India)

ITEM	WHY
Business entity Proprietorship, LLP or Pvt Ltd	Needed for Razorpay KYC, with a current account and PAN.
GST registration	Generally required for services above about ₹20 lakh turnover; Razorpay may ask for a GSTIN; invoices must then be GST-compliant.
Trademark	Register "JustCmul8" to protect the name.
Later, for enterprise sales	SOC 2 or ISO 27001; cyber insurance.

Orientation, not legal advice: confirm thresholds and registrations with a chartered accountant and a lawyer.

11 NEXT STEPS

The ordered to-do list

Effort: S = under a day, M = a few days. "Unlocks" says what each step makes possible. Growth and enterprise items are in roadmap phase 3 on the next page.

#	ACTION	OWNER	EFFORT	UNLOCKS
Before taking payments				
1	Remove "Trusted by" logos and the unreal Enterprise features	CODE	S	Removes legal risk now
2	Upgrade Vercel and Supabase plans; enable backups	TEAM	S	Commercial use allowed
3	Production email sender (Resend/SES) for auth and invites	TEAM	S	Real users can sign up
4	Sentry, `error.tsx`, `global-error.tsx`, uptime alerts	CODE	S	We see failures first
5	Deploy engine fixes; add golden-result tests	CODE	M	Trustworthy results in demos
6	Refund policy page, Razorpay KYC, live keys, plans and webhook	TEAM	M	Real payments
7	Gemini paid tier, budget alert, daily token caps	BOTH	S	AI privacy and cost control
8	Domain and email; private repository; staging database	TEAM	S	Professional, safe testing
First month after launch				
9	Cursor throttle, dashboard query, indexes, RLS tuning	CODE	S	Handles many users
10	Self-host Pyodide and pinned SimPy; video to a media CDN	CODE	M	No third-party outage risk
11	CI pipeline, Dependabot, branch protection, preview deploys	CODE	M	Safe, repeatable releases
12	Turnstile, MFA, audit log (1 year), share-link expiry	CODE	M	OWASP A06, A07, A09
13	"Download my data", AI-consent toggle, grievance contact, retention schedule	CODE	M	DPDP rights complete
14	Breach runbook, processor DPAs, legal review	TEAM	M	DPDP by May 2027
15	k6 load test; OWASP ZAP scan or pentest	BOTH	M	Evidence for customers

11 ROADMAP

Four phases to production

Code work and account work run in parallel. Phase 0 is the gate for taking real payments.

✓

Security sprint

done · 26 Oct 2026

SHIPPED

Critical dependency fixes · DPDP sign-up consent and record · 18+ gate · policy updates · deletion confirmation · older-browser fix

ALSO DONE

Engine accuracy fixes (breakdowns, priority, decision paths, line rules) · Simulation Playbook with canvas diagrams

0

Launch blockers

about 1–2 weeks

CODE

Remove fake logos and claims · error pages · Sentry · deploy engine fixes

TEAM

Vercel and Supabase Pro · email sender · Razorpay KYC and live keys · Gemini billing · domain · private repo · refund policy

1

Scale and process

first month

CODE

Cursor throttle · query and index fixes · self-hosted engine · CI and Dependabot

TEAM

Staging project · load test · branch protection

2

Security and privacy depth

months 1–3

CODE

Turnstile · MFA · audit log · share-link expiry · CSP nonces · data download · AI-consent toggle · red-team tests

TEAM

Pentest · breach runbook · DPAs · grievance contact · legal review

3

Large scale and enterprise

later

CODE

Yjs collaboration · AI queue · real SSO and dedicated compute

TEAM

Higher Supabase and Gemini tiers · SOC 2 / ISO 27001 · insurance

12 SOURCES, METHOD & LIMITS

How this was assessed

Findings come from reading the `justcmul8-rebuild` source at `e02477d` (API routes, Supabase SQL, realtime, AI and engine code, CSP configuration), `npm audit`, a licence scan of `node_modules`, inspection of the live site, automated test runs, and the published documentation below, checked in October 2026.

1. OWASP Top 10:2025 — owasp.org/Top10/2025
2. OWASP Top 10 for LLM Applications 2025 — hackerone.com (summary)
3. DPDP Rules 2025, fiduciary obligations — medianama.com
4. DPDP Rules 2025 highlights — scconline.com
5. DPDP Rules 2025 (EY) — ey.com
6. DPDP timeline (Taxmann) — taxmann.com
7. Supabase Realtime limits — supabase.com/docs/guides/realtime/limits
8. Supabase Auth SMTP — supabase.com/docs/guides/auth/auth-smtp
9. Supabase pricing — supabase.com/pricing
10. Vercel fair-use guidelines — vercel.com/docs/limits/fair-use-guidelines
11. Razorpay quickstart (KYC, live mode) — razorpay.com/docs/payments/quickstart
12. Gemini API rate limits — ai.google.dev/gemini-api/docs/rate-limits
13. Next.js advisory GHSA-6gpp-xcg3-4w24 — github.com/advisories
14. DOMPurify advisory GHSA-p98j-92pf-mc4p — github.com/advisories

Limitations

No load test or pentest was run. Production plan tiers, SMTP settings, the Gemini billing tier and live Razorpay key mode could not be inspected. DPDP details come partly from secondary summaries of the Rules. Licence and registration notes are orientation only; confirm with a chartered accountant and a lawyer. The KPI unit-label finding is reported but not yet confirmed.